SECURITY

Key Management Visual Guide

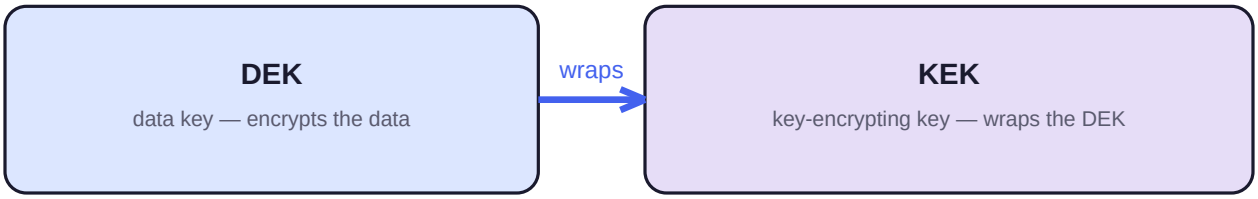
KMS, HSMs, envelope encryption —
keys are the crown jewels; treat them that way.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

Envelope Encryption

Encrypt data with a data key; encrypt the data key with a master key.

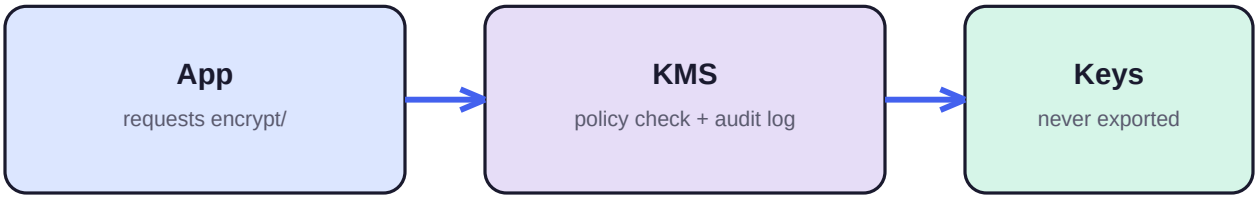


Store the encrypted DEK next to the data; the KEK never leaves the KMS/HSM. Rotating the KEK re-wraps DEKs — no data re-encryption needed.

STEP 2/6

KMS Architecture

Central key service with policy + audit on every use.

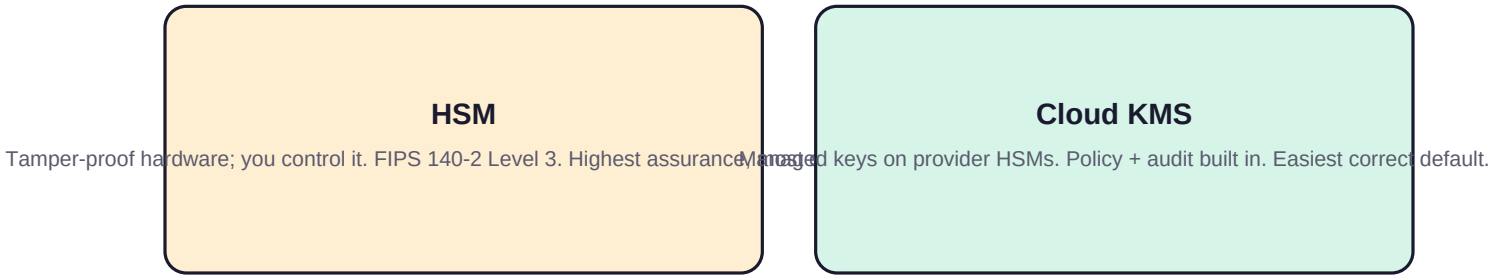


Apps get ciphertext and plaintext back — never the raw key. Every operation is logged: who used which key, when.

STEP 3/6

HSM vs Cloud KMS

Hardware roots of trust vs managed service.



Rule of thumb: cloud KMS unless regulation or threat model demands your own HSMs.

STEP 4/6

Key Rotation, Done Right

Rotate on a schedule — and be able to rotate in an emergency.

New data uses the new key; old keys stay available (decrypt-only) until all data is re-wrapped. Test emergency rotation before you need it.

STEP 5/6

Separation of Duties

No single person should own a key end-to-end.

- Key custodians create and back up keys; operators use them via policy — different people.
- Require multi-party approval (m-of-n) for destructive actions: delete key, export, disable.
- Break-glass procedures exist but every use pages security and leaves an audit trail.
- Developers get encrypt/decrypt rights; nobody gets raw key material.

STEP 6/6

Key Lifecycle Checklist

From birth to destruction.

- Generate in the KMS/HSM with a strong RNG — never on a laptop.
- Tag every key: owner, purpose, rotation schedule, data classification.
- Automate rotation; alert on rotation failures and stale keys.
- Destroy securely at end of life: crypto-shred by deleting the key (data becomes unreadable).
- Back up HSM master keys as split shares in separate safes — losing them loses everything.

STEP ✓I✓

Key Takeaways

Key Management — Remember

- Envelope encryption: DEKs encrypt data, KEKs wrap DEKs and never leave the KMS/HSM.
- Apps see plaintext/ciphertext, never raw keys; every use is policy-checked and logged.
- Cloud KMS is the sane default; own HSMs only when compliance demands it.
- Rotate on schedule, keep old keys decrypt-only, and rehearse emergency rotation.
- Separate duties: creators ≠ users; m-of-n approval for destructive actions.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev